



دانشکده مهندسی

گروه مهندسی کامپیوتر

مقطع کارشناسی

عنوان

بخش نظری

توضیح مفاهیم و منابع مربوط به agent tesla

نگارش

فائزه باقریان گل

استاد راهنما

دکتر عباس قائمی بافقی

بهمن ۱۴۰۴

اول

با گسترش روزافزون استفاده از فناوری‌های دیجیتال، سرویس‌های آنلاین، ایمیل‌های سازمانی و ابزارهای مبتنی بر وب، ماهیت تهدیدات سایبری نیز دچار تحول شده است. در این بین تمرکز بسیاری از مهاجمان از حملات مخرب و پر سر و صدا به سمت حملات کم‌هزینه، پنهان و مبتنی بر سرقت اطلاعات تغییر یافته است. بدافزارهای سرقت اطلاعات (Infostealer Malware) نمونه‌ای شاخص از این تغییر رویکرد محسوب می‌شوند که بدون ایجاد اختلال محسوس در عملکرد سیستم، اطلاعات حساس کاربران و سازمان‌ها را استخراج و برای سوءاستفاده‌های بعدی در اختیار مهاجمان قرار می‌دهند.

بخش نظری این فعالیت با هدف ایجاد درک مفهومی و تحلیلی از بدافزارهای Infostealer و بررسی جایگاه آن‌ها در زنجیره حملات سایبری مدرن تدوین شده است. ابتدا مفهوم Infostealer Malware و نقش آن در چارچوب‌هایی مانند Cyber Kill Chain مورد بررسی قرار می‌گیرد تا مشخص شود این دسته از بدافزارها چگونه به‌عنوان نقطه آغاز یا تسهیل‌کننده حملات پیچیده‌تر عمل می‌کنند. سپس، بدافزار Agent Tesla به‌عنوان یکی از شناخته‌شده‌ترین و ماندگارترین نمونه‌های Infostealer، به‌صورت مطالعه موردی (Case Study) معرفی و تحلیل می‌شود.

مبنای این بخش نظری، مطالعه و تشریح گزارش‌های فنی و مستندات معتبر منتشرشده توسط مراکز رسمی امنیت سایبری و نهادهای پژوهشی است. از جمله این منابع می‌توان به گزارش فنی «Agent Tesla Malware – Technical Analysis» و گزارش راهبردی «The Silent Heist: Information Stealer Malware» اشاره کرد که هر یک از زاویه‌ای متفاوت به تحلیل این تهدید می‌پردازند. در این بخش، تلاش شده است با مرور روزنامه‌ای این منابع و تحلیل محتوای آن‌ها، تصویری منسجم از نحوه عملکرد، قابلیت‌ها، روش‌های توزیع و چالش‌های شناسایی بدافزارهای سرقت اطلاعات ارائه شود.

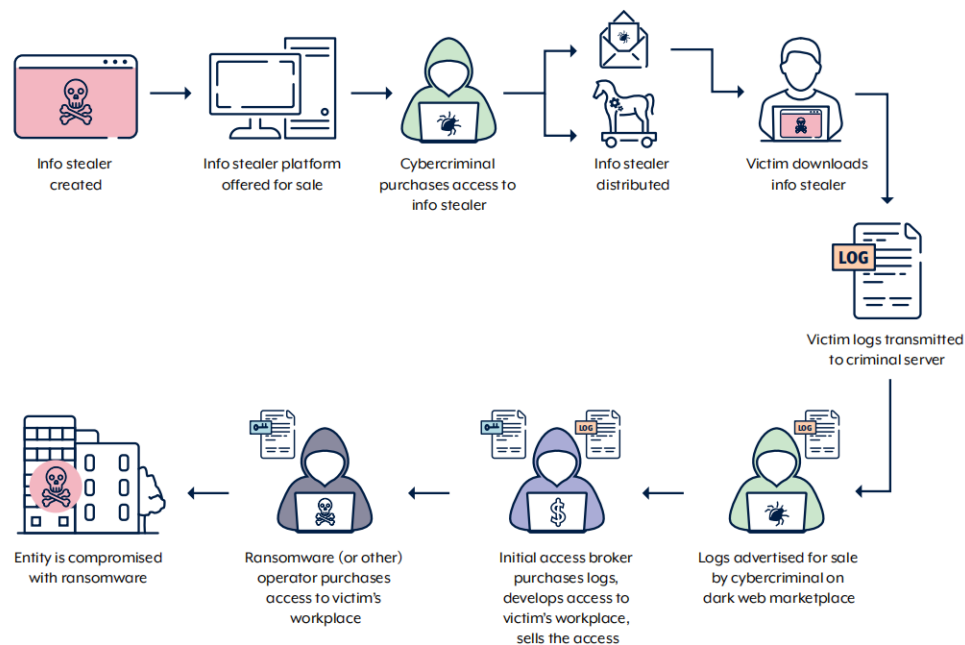
در نهایت، این بخش نظری به‌گونه‌ای طراحی شده است که علاوه بر پوشش مباحث مفهومی و تحلیلی، زمینه لازم برای بخش عملی فعالیت را فراهم کند. به عبارت دیگر، هدف از این بخش صرفاً ارائه اطلاعات نظری نیست، بلکه ایجاد پیوند میان دانش نظری و درک عملی از رفتار بدافزارها و ردپاهای آن‌ها در محیط‌های واقعی است.

۲	چکیده
۳	فهرست مطالب
۴	۱. تعریف Infostealer Malware و جایگاه آن در زنجیره حملات سایبری
۴	1.1. تعریف بدافزارهای سرقت اطلاعات
۴	1.2. تحلیل جایگاه Infostealerها در حملات سایبری
۶	۲. معرفی Agent Tesla به عنوان Malware-as-a-Service و دلایل ماندگاری آن
۶	۲/۱. معرفی Agent Tesla
۷	۳. بررسی قابلیت‌های فنی Agent Tesla
۷	۳.۱. ثبت ضربات کلید (Keylogging)
۷	۳.۲. سرقت اطلاعات مرورگرها و ایمیل کلاینت‌ها
۷	۳.۳. ارسال داده‌های سرقت‌شده (Exfiltration)
۸	۴. تحلیل روش‌های توزیع Agent Tesla
۸	۴.۱. ایمیل‌های فیشینگ
۸	۴.۲. پیوست‌های Office و PDF آلوده
۸	۴.۳. Obfuscation و Pack کردن فایل اجرایی
۱۰	۵. نگاشت رفتار Agent Tesla با چارچوب MITRE ATT&CK
۱۱	۶. توضیح منابع
۱۱	6.1. Agent Tesla Malware – Technical Analysis (2024)[2]
۱۲	6.2. The Silent Heist: Information Stealer Malware[1]
۱۴	6.3. Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains
۱۵	۷. جمع‌بندی بخش نظری
۱۶	منابع

۱. تعریف Infostealer Malware و جایگاه آن در زنجیره حملات سایبری

۱.۱. تعریف بدافزارهای سرقت اطلاعات

بدافزارهای سرقت اطلاعات (Infostealer Malware) به دسته‌ای از بدافزارها گفته می‌شوند که هدف اصلی آن‌ها جمع‌آوری پنهانی اطلاعات حساس مانند نام کاربری، گذرواژه، داده‌های مرورگر و تنظیمات ایمیل از سیستم قربانی است، بدون آن‌که اختلال آشکاری در عملکرد سیستم ایجاد کنند. Infostealerها به عنوان تهدیداتی معرفی می‌شوند که تمرکز آن‌ها بر سرقت تدریجی اطلاعات و ماندگاری طولانی در سیستم است، نه تخریب فوری. اهمیت Infostealerها در این است که اغلب نقطه آغاز زنجیره حملات بزرگ‌تر محسوب می‌شوند. اطلاعاتی که توسط این بدافزارها جمع‌آوری می‌شود، می‌تواند در مراحل بعدی برای نفوذ به شبکه‌های سازمانی، کلاهبرداری‌های مالی یا حملات مهندسی اجتماعی پیشرفته‌تر مورد استفاده قرار گیرد. بنابراین، Infostealer Malware به تنهایی هدف نهایی مهاجم نیست، بلکه ابزاری برای دستیابی به اهداف بعدی است [1].



شکل ۱.۱.۱. چرخه سرقت اطلاعات و تاثیرات احتمالی روی سازمان‌ها [1]

۱.۲. تحلیل جایگاه Infostealerها در حملات سایبری

برای تحلیل جایگاه Infostealerها در حملات سایبری، چارچوب **Intrusion Kill Chain** ارائه شده توسط Cloppert، Hutchins و Amin در مقاله معروف Lockheed Martin کاربرد دارد. این چارچوب نشان می‌دهد که مهاجم برای رسیدن به هدف خود از مراحل مشخصی مانند نفوذ اولیه، اجرا و در نهایت دستیابی به هدف عبور می‌کند. با تطبیق این مدل با رفتار Infostealerها، مشخص می‌شود که این بدافزارها عمدتاً در مراحل **Execution**، **Delivery** و **Actions on Objectives** فعال هستند؛ جایی که هدف نهایی نه تخریب سیستم، بلکه سرقت اطلاعات است [3].

Infostealerهایی مانند Agent Tesla بدون استفاده از exploit های پیچیده، با تکیه بر فیشینگ ایمیلی و تعامل کاربر، می توانند بخش قابل توجهی از Kill Chain را طی کنند. این سادگی عملیاتی باعث می شود بسیاری از مکانیزم های دفاعی سنتی در شناسایی آنها ناکارآمد باشند [2].

۲. معرفی Agent Tesla به عنوان Malware-as-a-Service و دلایل ماندگاری آن

۲/۱. معرفی Agent Tesla

Agent Tesla یکی از شناخته شده ترین بدافزارهای سرقت اطلاعات است که به صورت Malware-as-a-Service (MaaS) عرضه می شود. در این مدل، توسعه دهنده بدافزار ابزار را فراهم می کند و مهاجمان مختلف می توانند بدون نیاز به دانش فنی بالا از آن استفاده کنند. گزارش فنی (Agent Tesla Malware – Technical Analysis (2024) این مدل تجاری را یکی از عوامل اصلی گسترش و تداوم استفاده از Agent Tesla معرفی می کند [2].

Agent Tesla از حدود سال ۲۰۱۴ تاکنون در کمپین های فیشینگ متعددی مشاهده شده و علی رغم قدمت، همچنان فعال است. بر اساس گزارش مذکور، دلیل این ماندگاری سادگی معماری، توسعه مبتنی بر NET. و امکان شخصی سازی آسان است. این بدافزار دارای ساختاری ماژولار است که شامل بخش های جمع آوری اطلاعات، ثبت کلیدها، استخراج داده های مرورگر و ایمیل و ارسال اطلاعات سرقت شده می شود.

گزارش The Silent Heist: Information Stealer Malware از ACSC نیز Agent Tesla را نمونه ای از یک Infostealer کم هزینه اما مؤثر معرفی می کند که با استفاده از روش های ساده مانند فیشینگ ایمیلی و کانال های ارتباطی رایج، می تواند برای مدت طولانی بدون شناسایی فعال باقی بماند. این ویژگی ها باعث شده اند Agent Tesla به عنوان نمونه ای مناسب برای تحلیل بدافزارهای سرقت اطلاعات در حملات سایبری مدرن شناخته شود [1].

۳. بررسی قابلیت‌های فنی Agent Tesla

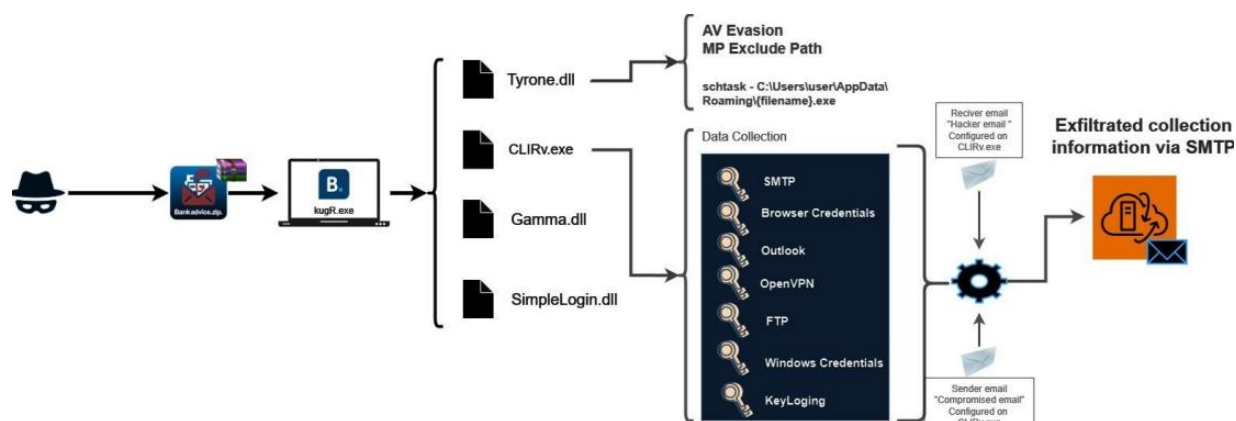
Agent Tesla به عنوان یک Infostealer، مجموعه‌ای از قابلیت‌های فنی را پیاده‌سازی می‌کند که هدف اصلی آن‌ها جمع‌آوری و ارسال اطلاعات حساس از سیستم قربانی است. گزارش فنی (2024) *Agent Tesla Malware – Technical Analysis* این قابلیت‌ها را ساده اما مؤثر توصیف می‌کند و تأکید دارد که تمرکز بدافزار بر داده‌هایی است که بیشترین ارزش عملی برای مهاجم دارند [2].

۳.۱. ثبت ضربات کلید (Keylogging)

Agent Tesla دارای قابلیت Keylogging در سطح سیستم است که امکان ثبت ورودی‌های صفحه‌کلید کاربر را فراهم می‌کند. با این حال، طبق گزارش فنی آلبانی و همچنین گزارش *The Silent Heist* از ACSC، نقش Keylogging در Agent Tesla نقش مکمل است و منبع اصلی داده‌های ارزشمند محسوب نمی‌شود. این قابلیت بیشتر برای تکمیل اطلاعاتی به کار می‌رود که از سایر منابع به دست آمده‌اند [1].

۳.۲. سرقت اطلاعات مرورگرها و ایمیل کلاینت‌ها

قابلیت اصلی Agent Tesla، استخراج اطلاعات ذخیره‌شده در مرورگرها و کلاینت‌های ایمیل است. این بدافزار می‌تواند داده‌هایی مانند نام کاربری، گذرواژه‌های ذخیره‌شده و تنظیمات ایمیل را از مرورگرهایی نظیر Chrome و Edge و کلاینت‌هایی مانند Outlook استخراج کند. گزارش‌ها تأکید می‌کنند که این نوع اطلاعات به دلیل قابلیت استفاده مجدد در حملات دیگر، ارزش بالاتری نسبت به داده‌های حاصل از Keylogging دارند.



شکل ۳.۲.۱. سرقت اطلاعات از طریق فایل‌های آلوده [2]

۳.۳. ارسال داده‌های سرقت‌شده (Exfiltration)

پس از جمع‌آوری اطلاعات، Agent Tesla داده‌ها را از طریق کانال‌هایی مانند SMTP، FTP و در برخی نسخه‌ها API پیام‌رسان‌ها ارسال می‌کند. طبق گزارش ACSC، استفاده از این کانال‌ها به دلیل رایج بودن در شبکه‌های سازمانی، احتمال شناسایی بدافزار را کاهش می‌دهد. این سادگی در Exfiltration یکی از عوامل موفقیت عملی Agent Tesla عنوان شده است [1].

در مجموع، قابلیت‌های فنی Agent Tesla نشان می‌دهند که این بدافزار با تمرکز بر سرقت مؤثر و کم‌هزینه اطلاعات و نه پیچیدگی فنی، توانسته است جایگاه پایداری در میان تهدیدات سایبری مدرن به دست آورد.

۴. تحلیل روش‌های توزیع Agent Tesla

یکی از عوامل موفقیت Agent Tesla، استفاده از روش‌های توزیع ساده اما بسیار مؤثر است. این بدافزار عمدتاً از مهندسی اجتماعی و فیشینگ ایمیلی برای دسترسی اولیه به سیستم قربانی استفاده می‌کند و وابستگی کمی به آسیب‌پذیری‌های فنی پیچیده دارد [1],[2].



شکل ۴.۱. روش‌های مورد استفاده در سرقت اطلاعات [1]

۴.۱ ایمیل‌های فیشینگ

ایمیل‌های فیشینگ رایج‌ترین روش توزیع Agent Tesla هستند. در این روش، مهاجم با ارسال ایمیل‌هایی با ظاهر قانونی (مانند فاکتور، اعلان پرداخت یا پیام سازمانی)، کاربر را به باز کردن پیوست یا کلیک روی لینک ترغیب می‌کند. گزارش‌ها تأکید می‌کنند که اتکای Agent Tesla به تعامل کاربر، باعث می‌شود بسیاری از مکانیزم‌های دفاعی مبتنی بر exploit عملاً دور زده شوند.

۴.۲ پیوست‌های Office و PDF آلوده

Agent Tesla اغلب در قالب پیوست‌های Office یا PDF توزیع می‌شود. این فایل‌ها معمولاً به گونه‌ای طراحی شده‌اند که اجرای فایل مخرب را به عنوان بخشی از یک فرایند عادی به کاربر القا کنند. گزارش فنی آلبانی اشاره می‌کند که استفاده از این فرمت‌ها به دلیل رایج بودن در محیط‌های کاری، احتمال موفقیت حمله را افزایش می‌دهد.

۴.۳ Obfuscation و Pack کردن فایل اجرایی

برای کاهش احتمال شناسایی، فایل اجرایی Agent Tesla معمولاً با استفاده از تکنیک‌های Obfuscation یا Pack کردن پنهان می‌شود. طبق گزارش‌ها، این تکنیک‌ها اگرچه پیشرفته نیستند، اما برای دور زدن شناسایی‌های مبتنی بر امضا کافی هستند و به ماندگاری بدافزار در کمپین‌های فیشینگ کمک می‌کنند.

در مجموع، روش‌های توزیع Agent Tesla نشان می‌دهند که ساده‌بودن و شباهت به فعالیت‌های عادی کاربر، یکی از مؤثرترین راهکارها برای نفوذ اولیه در حملات سایبری مدرن است.

۵. نگاشت رفتار Agent Tesla با چارچوب MITRE ATT&CK

برای تحلیل ساخت یافته رفتار بدافزارها، استفاده از چارچوب MITRE ATT&CK یکی از رایج ترین و کاربردی ترین روش ها در حوزه امنیت سایبری است. این چارچوب با دسته بندی رفتارهای مهاجم در قالب Tactic و Technique، به تحلیل گران کمک می کند تا فعالیت بدافزار را به صورت مرحله به مرحله درک و مستندسازی کنند. در گزارش فنی *Agent Tesla Malware – Technical Analysis* (2024) نیز رفتارهای این بدافزار به صورت ضمنی با مفاهیم MITRE ATT&CK قابل نگاشت هستند [2].

بر اساس تحلیل گزارش ها، Agent Tesla در مرحله Initial Access اعمداً با تکنیک (T1566) Phishing وارد سیستم قربانی می شود. پس از آن، در مرحله Execution از اجرای فایل پیوست شده یا اسکریپت های ساده برای فعال سازی بدافزار استفاده می کند که با تکنیک (T1204) User Execution هم خوانی دارد. این وابستگی به تعامل کاربر یکی از ویژگی های کلیدی Agent Tesla است [2]. در مرحله Credential Access، قابلیت های استخراج اطلاعات مرورگرها و کلاینت های ایمیل Agent Tesla با تکنیک Credential Dumping / Credential Harvesting (T1555) قابل تطبیق است. همچنین قابلیت Keylogging این بدافزار با تکنیک Input Capture (T1056) هم راستا است، هر چند طبق گزارش ها نقش آن مکمل محسوب می شود [2].

در نهایت، ارسال اطلاعات سرقت شده از طریق SMTP، FTP یا API پیام رسان ها با تکنیک های مرتبط با (T1041) Exfiltration در چارچوب MITRE ATT&CK تطبیق دارد. این نگاشت نشان می دهد که Agent Tesla با استفاده از مجموعه ای محدود اما مؤثر از تکنیک ها، می تواند بخش قابل توجهی از چرخه حمله را پوشش دهد [2].

در مجموع، استفاده از چارچوب MITRE ATT&CK امکان تحلیل منسجم و قابل مقایسه رفتار Agent Tesla را فراهم می کند و به مدافعان کمک می کند تا به جای تمرکز بر نمونه خاص بدافزار، الگوهای رفتاری قابل شناسایی و قابل مقابله را استخراج کنند.

6.1. Agent Tesla Malware – Technical Analysis (2024)[2]

ناشر: National Authority for Electronic Certification and Cyber Security (Albania)

۶/۱/۱. بخش اول: بررسی عنوان و چکیده مقاله

۶،۱،۱،۱. تحلیل عنوان مقاله

عنوان گزارش «Agent Tesla Malware – Technical Analysis» به روشنی نشان می‌دهد که تمرکز اصلی سند بر تحلیل فنی یک نمونه مشخص از بدافزارهای سرقت اطلاعات است. استفاده از نام مستقیم بدافزار (Agent Tesla) بیانگر رویکرد مطالعه موردی است و عبارت «Technical Analysis» مشخص می‌کند که گزارش، رویکرد توصیفی یا عمومی ندارد، بلکه به بررسی رفتار، معماری و قابلیت‌های فنی بدافزار می‌پردازد.

در این عنوان، به جای استفاده از عباراتی مانند «Overview» یا «Threat Landscape»، واژه «Technical» انتخاب شده که مخاطب هدف گزارش را تحلیل‌گران امنیت، تیم‌های SOC و متخصصان پاسخ به رخداد مشخص می‌کند. بنابراین، عنوان مقاله نشان می‌دهد که هدف آن افزایش درک عملی و فنی از عملکرد Agent Tesla است.

۶،۱،۱،۲. تحلیل چکیده (Abstract)

چکیده بر این نکته تأکید دارد که Agent Tesla یکی از بدافزارهای سرقت اطلاعات با سابقه است که علی‌رغم قدمت، همچنان در حملات سایبری مدرن مورد استفاده قرار می‌گیرد. هدف اصلی گزارش، ارائه یک تحلیل فنی از روش‌های عملکرد، قابلیت‌های سرقت اطلاعات، نحوه انتشار و تکنیک‌های ارسال داده‌های سرقت شده است.

در چکیده همچنین اشاره می‌شود که این بدافزار عمدتاً از طریق کمپین‌های فیشینگ منتشر می‌شود و با تکیه بر روش‌های ساده اما مؤثر، اطلاعات حساس کاربران را استخراج و منتقل می‌کند. مقاله تلاش می‌کند نشان دهد که چرا بدافزارهایی با پیچیدگی کم، همچنان می‌توانند در محیط‌های واقعی موفق عمل کنند و چه چالش‌هایی برای شناسایی آن‌ها وجود دارد.

در مجموع، چکیده به روشنی بیان می‌کند که تمرکز گزارش بر رفتار عملی بدافزار و پیامدهای امنیتی آن برای مدافعان است.

۶،۱،۲. بخش دوم: مرور روزنامه‌ای گزارش

گزارش پس از مقدمه، بحث خود را با معرفی جایگاه Agent Tesla در میان بدافزارهای سرقت اطلاعات آغاز می‌کند. نویسندگان توضیح می‌دهند که این بدافزار نمونه‌ای از Malware-as-a-Service است که به مهاجمان مختلف با سطوح مهارتی متفاوت امکان استفاده از آن را می‌دهد. همین ویژگی باعث شده است که Agent Tesla در طول سال‌ها به طور مستمر در کمپین‌های مختلف مشاهده شود.

در ادامه، مقاله به بررسی معماری کلی بدافزار می‌پردازد و توضیح می‌دهد که Agent Tesla عمدتاً بر پایه NET Framework. توسعه داده شده است. این انتخاب از دید نویسندگان، مزایایی مانند سازگاری گسترده با سیستم‌عامل ویندوز، سهولت توسعه و امکان پنهان‌سازی کد را برای مهاجم فراهم می‌کند.

بخش بعدی مقاله به قابلیت‌های فنی Agent Tesla اختصاص دارد. در این بخش توضیح داده می‌شود که بدافزار قادر به جمع‌آوری اطلاعات متنوعی از سیستم قربانی است. از جمله اطلاعات ذخیره‌شده در مرورگرها، داده‌های مربوط به ایمیل کلاینت‌ها و ورودی‌های صفحه‌کلید. مقاله تأکید می‌کند که تمرکز اصلی بدافزار بر سرقت اعتبارنامه‌های ذخیره‌شده است و قابلیت Keylogging نقش تکمیلی دارد.

در ادامه، مقاله روش‌های ارسال اطلاعات سرقت‌شده را بررسی می‌کند. طبق گزارش، Agent Tesla از کانال‌هایی مانند SMTP، FTP و در برخی نسخه‌ها API پیام‌رسان‌ها برای انتقال داده استفاده می‌کند. این روش‌ها به گونه‌ای انتخاب شده‌اند که در اغلب شبکه‌ها مجاز بوده و کمتر جلب توجه کنند.

در بخش‌های بعدی، مقاله به روش‌های توزیع بدافزار می‌پردازد و توضیح می‌دهد که کمپین‌های فیشینگ ایمیلی با پیوست‌های آلوده، رایج‌ترین شیوه انتشار Agent Tesla هستند. استفاده از فایل‌های Office، PDF و آرشیوهای فشرده از جمله تکنیک‌هایی است که در گزارش به آن اشاره شده است.

در پایان، مقاله به چالش‌های شناسایی Agent Tesla اشاره می‌کند و نشان می‌دهد که استفاده از تکنیک‌های ساده اما مؤثر باعث می‌شود این بدافزار بتواند برای مدت طولانی بدون شناسایی در سیستم قربانی فعال باقی بماند.

۳، ۱، ۶. بخش سوم: ابزارها و چارچوب‌های مورد استفاده در گزارش و پروژه

در این گزارش، ابزار خاصی به صورت نرم‌افزار اجرایی معرفی نشده است، اما نویسندگان به طور ضمنی به استفاده از چارچوب‌ها و مفاهیم استاندارد تحلیل بدافزار اشاره می‌کنند. از جمله مهم‌ترین آن‌ها می‌توان به چارچوب [MITRE ATT&CK](#) اشاره کرد که برای طبقه‌بندی رفتارهای بدافزار مورد استفاده قرار می‌گیرد.

همچنین گزارش به تحلیل رفتارهای بدافزار در سطح سیستم عامل ویندوز تکیه دارد و مفاهیمی مانند اجرای فرآیندها، ماندگاری از طریق Scheduled Task و ارتباطات شبکه‌ای را بررسی می‌کند. در بخش عملی حاضر نیز از همین مفاهیم برای شبیه‌سازی و تحلیل رفتار Agent Tesla استفاده شده است، بدون آنکه بدافزار واقعی اجرا شود.

6.2. The Silent Heist: Information Stealer Malware^[1]

ناشر: Australian Cyber Security Centre (ACSC)

۱/۲/۶. بخش اول: بررسی عنوان و چکیده مقاله

۱، ۱، ۲، ۶. تحلیل عنوان مقاله

عنوان «The Silent Heist: Information Stealer Malware» به صورت هدفمند و مفهومی انتخاب شده است. استفاده از عبارت «Silent Heist» (سرقت خاموش) نشان‌دهنده ماهیت اصلی بدافزارهای سرقت اطلاعات است؛ حملاتی که بدون ایجاد اختلال محسوس، بدون تخریب سیستم و اغلب بدون جلب توجه کاربر یا مدیر سیستم، اطلاعات حساس را به سرقت می‌برند.

برخلاف مقاله اول که عنوانی فنی و مشخص دارد، این عنوان رویکردی مفهومی و راهبردی اتخاذ کرده است. تمرکز عنوان بر پدیده Infostealer به صورت کلی است، نه یک نمونه خاص. این موضوع نشان می‌دهد که مقاله قصد دارد تصویری کلان از تهدید ارائه دهد و مخاطب آن علاوه بر تحلیل گران فنی، تصمیم‌گیران امنیتی و مدیران سازمانی نیز هستند.

۶,۲,۱,۲. تحلیل چکیده (Abstract)

چکیده مقاله توضیح می‌دهد که بدافزارهای سرقت اطلاعات به یکی از رایج‌ترین و در عین حال کم‌سروصداترین تهدیدات سایبری تبدیل شده‌اند. هدف اصلی گزارش، افزایش آگاهی نسبت به نحوه عملکرد این بدافزارها، پیامدهای امنیتی آن‌ها و چرایی اثربخشی‌شان در محیط‌های واقعی است.

در چکیده تأکید می‌شود که Infostealer ها معمولاً به عنوان نقطه شروع زنجیره حملات بزرگ‌تر عمل می‌کنند و داده‌های سرقت‌شده توسط آن‌ها می‌تواند در حملات بعدی مورد سوءاستفاده قرار گیرد. چکیده همچنین بیان می‌کند که شناسایی این تهدیدات به دلیل شباهت رفتار آن‌ها به فعالیت‌های عادی کاربران، چالش برانگیز است.

در مجموع، چکیده نشان می‌دهد که مقاله با هدف تحلیل تهدید در سطح کلان و ارائه دیدگاه دفاعی نوشته شده است، نه بررسی فنی یک بدافزار خاص.

۶,۲,۲. بخش دوم: مرور روزنامه‌ای گزارش

مقاله «The Silent Heist» بحث خود را با تشریح مفهوم Infostealer Malware آغاز می‌کند و توضیح می‌دهد که چرا این دسته از بدافزارها در سال‌های اخیر رشد چشمگیری داشته‌اند. نویسندگان مقاله اشاره می‌کنند که افزایش استفاده از مرورگرها برای ذخیره گذرواژه‌ها، ایمیل‌های سازمانی و سرویس‌های ابری، فرصت مناسبی برای این نوع بدافزارها ایجاد کرده است.

در ادامه، مقاله به این نکته می‌پردازد که برخلاف تصور رایج، بدافزارهای سرقت اطلاعات لزوماً پیچیده یا مبتنی بر exploit های پیشرفته نیستند. در بسیاری از موارد، این بدافزارها از روش‌های ساده اما مؤثر استفاده می‌کنند و همین سادگی باعث می‌شود نرخ موفقیت آن‌ها بالا باشد.

بخش بعدی مقاله به بررسی زنجیره حمله Infostealer ها اختصاص دارد. نویسندگان توضیح می‌دهند که این زنجیره معمولاً با یک ایمیل فیشینگ آغاز می‌شود و پس از اجرای فایل توسط کاربر، بدافزار شروع به جمع‌آوری اطلاعات ذخیره‌شده در سیستم می‌کند. این اطلاعات شامل اعتبارنامه‌ها، داده‌های مرورگر و تنظیمات ایمیل است.

در ادامه، مقاله به مرحله ارسال اطلاعات سرقت‌شده می‌پردازد و توضیح می‌دهد که مهاجمان معمولاً از کانال‌هایی استفاده می‌کنند که در اغلب شبکه‌ها مجاز هستند، مانند HTTP ، SMTP یا API پیام‌رسان‌ها. این انتخاب باعث می‌شود ترافیک مخرب در میان ترافیک عادی پنهان شود.

در بخش‌های بعدی، مقاله پیامدهای امنیتی Infostealer ها را بررسی می‌کند. نویسندگان تأکید می‌کنند که خسارت اصلی این بدافزارها اغلب با تأخیر ظاهر می‌شود و داده‌های سرقت‌شده می‌توانند در حملات بعدی مانند نفوذ به شبکه‌های سازمانی یا کلاهبرداری‌های مالی مورد استفاده قرار گیرند.

در پایان، مقاله به چالش‌های شناسایی و مقابله با Infostealer ها اشاره می‌کند و نشان می‌دهد که تمرکز صرف بر شناسایی فایل‌های مخرب کافی نیست و تحلیل رفتار فرآیندها و الگوهای ارتباطی اهمیت بیشتری دارد.

۳، ۲، ۶. بخش سوم: ابزارها و چارچوب‌های مورد استفاده در مقاله و پروژه

در این گزارش، تمرکز اصلی بر ابزارهای اجرایی خاص نیست، بلکه بر چارچوب‌ها و مفاهیم دفاعی تأکید شده است. مهم‌ترین چارچوب مورد اشاره در مقاله، تحلیل زنجیره حمله و رفتار بدافزارها در سطح سیستم‌عامل و شبکه است.

مقاله به‌طور غیرمستقیم به استفاده از چارچوب‌هایی مانند [MITRE ATT&CK](#) برای درک و طبقه‌بندی رفتارهای مهاجم اشاره دارد، هرچند وارد جزئیات فنی هر ابزار نمی‌شود. همچنین مفاهیمی مانند مانیتورینگ رفتار، تحلیل لاگ‌ها و تشخیص الگوهای غیرعادی به‌عنوان ابزارهای کلیدی دفاع مطرح می‌شوند.

در بخش عملی حاضر نیز از همین رویکرد استفاده شده است؛ به‌گونه‌ای که به‌جای تمرکز بر اجرای بدافزار واقعی، رفتارهای کلیدی مانند جمع‌آوری داده و تلاش برای ارسال اطلاعات شبیه‌سازی و تحلیل شده‌اند.

6.3. Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains

علاوه بر این دو گزارش، مقاله کلاسیک Hutchins، Cloppert و Amin با عنوان *Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains* چارچوب تحلیلی مناسبی برای قرار دادن رفتار Infostealer ها در زنجیره حملات سایبری ارائه می‌دهد. این مقاله به‌صورت مستقیم به Agent Tesla نمی‌پردازد اما ابزار مفهومی لازم برای تحلیل جایگاه آن در حملات مدرن را فراهم می‌کند.

در مجموع، مرور این منابع نشان می‌دهد که ترکیب تحلیل‌های فنی موردی و گزارش‌های راهبردی کلان، دیدی کامل‌تر از تهدید Infostealer Malware ارائه می‌دهد Agent Tesla در این میان به‌عنوان نمونه‌ای عملی از مفاهیم مطرح‌شده در این منابع شناخته می‌شود و مطالعه آن امکان پیوند میان تحلیل نظری و درک عملی رفتار مهاجمان را فراهم می‌کند.

۷. جمع‌بندی بخش نظری

در این بخش نظری، بدافزارهای سرقت اطلاعات (Infostealer Malware) به‌عنوان یکی از تهدیدات کلیدی و پایدار در حملات سایبری مدرن مورد بررسی قرار گرفتند. با تکیه بر گزارش‌های معتبر امنیتی، مشخص شد که Infostealer ها برخلاف بدافزارهای مخرب پرسروصدا، با تمرکز بر سرقت پنهانی اطلاعات و استفاده از روش‌های ساده اما مؤثر، نقش مهمی در مراحل اولیه و میانی زنجیره حملات سایبری ایفا می‌کنند.

تحلیل موردی Agent Tesla نشان داد که این بدافزار به‌عنوان یک نمونه موفق از مدل Malware-as-a-Service، چگونه با معماری ساده، قابلیت‌های مشخص در جمع‌آوری اطلاعات و استفاده از کانال‌های ارتباطی رایج، توانسته است برای سال‌ها در کمپین‌های فیشینگ مورد استفاده قرار گیرد. بررسی قابلیت‌های فنی، روش‌های توزیع و نگاشت رفتار آن با چارچوب MITRE ATT&CK، نشان داد که موفقیت Agent Tesla بیش از آنکه ناشی از پیچیدگی فنی باشد، حاصل بهره‌گیری هوشمندانه از رفتارهای عادی کاربران و زیرساخت‌های مجاز شبکه است.

همچنین مرور گزارش‌های کلان مانند *The Silent Heist* و چارچوب تحلیلی Intrusion Kill Chain شرکت Lockheed Martin، این دیدگاه را تقویت کرد که Infostealer Malware معمولاً به‌عنوان تسهیل‌کننده حملات بعدی عمل می‌کند و تحلیل آن‌ها بدون در نظر گرفتن زنجیره کامل حمله، ناقص خواهد بود.

بر همین اساس، بخش عملی این فعالیت با هدف اجرای بدافزار واقعی طراحی نشده است بلکه تلاش می‌کند رفتارهای کلیدی استخراج‌شده از بخش نظری مانند روش‌های توزیع، جمع‌آوری اطلاعات و تلاش برای ارسال داده را به‌صورت کنترل‌شده و ایمن شبیه‌سازی و تحلیل کند. به این ترتیب، بخش نظری و عملی این فعالیت در کنار یکدیگر تصویری منسجم از نحوه عملکرد و شناسایی بدافزارهای Infostealer در محیط‌های واقعی ارائه می‌دهند.

- [1] [The Silent Heist: Information Stealer Malware\(2024_ Australian Cyber Security Centre \(ACSC\)\)](#)
- [2] [Agent Tesla Malware – Technical Analysis \(2024- National Authority for Electronic Certification and Cyber Security \(Albania\)\)](#)
- [3] [Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains\(Eric M. Hutchins*, Michael J. Cloppert† , Rohan M. Amin, Ph.D.‡ Lockheed Martin Corporation\)](#)
- [4] <https://attack.mitre.org/>